

7.15 audit unit 07b2 — groups, iteration and optional visibility

1. Identity and frozen scope

Owner: 7.15 firmware rehearsal. Worktree: /private/tmp/kk715-stack07b2, branch release/715-stack-07b2-erc7730-groups, [firmware draft #866](https://github.com/BitHighlander/keepkey-firmware/pull/866). Target: release/715-stack-07b1-erc7730-formatters at c5bf7433d13f141e5ef67f7a25723c7a81a84ec2. Code predecessor before this report: 2020f2e88222e6cc8b37f7638d977b61cbc375d0. Python companion: deps/python-keepkey at 8fc1c2bc038db8ee2c192b162c3308234117275e, [companion draft #115](https://github.com/BitHighlander/python-keepkey/pull/115). The main-worktree MASTER-AUDIT-TEMPLATE.md SHA256 is 743843a17139a7394325a961b9a38666c8e8af7a0005e0ff52eb94559ec8dbb7. This is a code-bearing adjacent PR diff. It adds D behavior to the accepted A-C predecessor; E embedded-call dispatch belongs to the following unit.

Groups structure fields without hiding them. An iteration walks exactly one array, reached through tuples, in a calldata definition. Every field inside must read that active array, so a scalar cannot be repeated for each element. Only the optional condition runs, and it always shows the field. All visibility rules that could hide a field are refused at preload. The host mirror makes the same decisions.

2. Git inventory and changed behavior

Immutable code inventory range: git diff --numstat c5bf7433d13f141e5ef67f7a25723c7a81a84ec2..2020f2e88222e6cc8b37f7638d977b61cbc375d0. The frozen inventory below also includes this source report and its PDF. Counts are net adjacent-diff counts, including tests, documentation and the Python gitlink. They do not sum overlapping historical commits. The PR body records the final report-containing head.

Tracked path	Added	Deleted	Change and evidence
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b2-groups-audit-20260926.md	102	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b2-groups-audit-20260926.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	18	0	Records on-screen behavior and fail-closed limits.
include/keepkey/firmware/erc7730_capabilities.h	15	7	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	9	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_workflow.h	13	0	Declares bounded state and the phase's runtime contract.
lib/firmware/erc7730_abi_stream.c	14	0	Captures only bounded ABI facts and records overflow.
lib/firmware/erc7730_capabilities.c	9	1	Selects the exact formatter and display capabilities.
lib/firmware/erc7730_catalog.c	63	12	Refuses unexecutable signed programs before review.
lib/firmware/erc7730_workflow.c	22	2	Keeps replay, validation and UI state in sequence.
lib/firmware/fsm_msg_ethereum.h	88	7	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	61	5	Exercises signed wire requests and review screens.
unittests/firmware/erc7730_catalog.cpp	151	15	Covers accepted neighbors and fail-closed boundaries.

Before D, the device refused group and iteration display instructions, so the official registry's array-backed descriptions could not be used. D checks array ownership before the first screen, counts elements in a validation pass and labels each element review. The same signed calldata is replayed for capture; a short auxiliary array fails closed. The catalog, workflow and wire tests exercise both accepted arrays and adjacent refusal cases. The compiler mirror is checked against the device validator.

3. Current-source findings and limits

Finding	Disposition and evidence
D10 parallel arrays	Value paths walk the active array. Other [] paths pair by index; short arrays fail closed, extra elements are not shown. The wire case documents this limit.
D14 iteration title	Each element uses a device-owned <code>Signer field i</code> of <code>N</code> title, distinct from the signer label.
D18 fixed index in a dynamic array	Preload cannot know its length; capture fails closed if the index is absent. The wire case documents this limit.
Copilot round 1 scalar reuse	The verifier and host mirror require the formatter value to walk the active array. Native catalog and Python/firmware negative controls pass.
Copilot round 2 display frame aliasing	A dedicated <code>display_frames</code> array prevents group and iteration frames from overwriting path classes. <code>DisplayFramesPreservePathClasses</code> passes.

The historical audit preserved D1–D19 clusters rather than all 42 raw rows; the top split receipt maps the surviving groups and names the evidence gap. The two D Copilot findings are repaired in this code-bearing unit. Physical device checks and release-promotion checks remain separate gates.

4. Verification and artifacts

Check	Exact source or run	Result and limit
Full native firmware	source-equivalent D code before report	<code>firmware-unit 652/652</code> passed in a clean run directory.
Focused iteration controls	same code	<code>PreloadChecksIterationAgainstTheArrayItWalks, DisplayFramesPreservePathClasses and IterationPathsReachTheirArrayThroughTuplesOnly</code> pass.
Host/device mirror	Python <code>8fc1c2b</code> , D validator	Seven focused compiler/validator cases pass.
Corrected cppcheck	D source, Ubuntu 24.04 CI flags	Zero findings.
First hosted split run	GitHub Actions <code>36268666305</code> , pre-report D head	ARM full/BTC passed; final job status was pending when this report was prepared. New report head needs its own exact-head run.
Wire and physical device	same hosted run	Wire job pending when prepared; physical device not used.

Canonical preflight passed submodule cleanliness, unit-test registration and clang-format 20. It failed on inherited duplicate Osmosis/Solana nanopb options, `scripts/test_generate_test_report.py` absent from the 7a base, and its own missing `.cppcheck-build` directory. The owner approved the 7b push with this exception recorded. The gate is not called passing.

5. Report preflight and review checkpoint

The readable source and PDF contain the same inventory. The PDF was opened and checked for legibility. The final PR head and live target SHA belong in the PR body after this report commit. `git diff --check` and clang-format 20 pass. This smaller adjacent diff has a fresh Copilot budget; none has been requested. The historical #863 reviews do not count as a clean exact-head review of this D diff.